Supplier Security Questionnaire App Specification Document

Module 1: Architecture, Data Model & ERD

1. Executive Summary & Overview

This document details the complete specification for the Proof of Concept (PoC) Supplier Security Questionnaire App designed for Procurement and Security teams. The application automates vendor onboarding, evaluates security risk through hybrid scoring, enforces human approval for high-risk vendors, and tracks annual reassessments.

Core Tech Stack

- **Backend/Frontend Framework:** Python (FastAPI with Jinja2/Material UI templates or Streamlit architecture)
- **Database:** SQLite (Zero-config local file-based database)
- **Design System:** Material UI styling

2. Entity Relationship Diagram (ERD) & Database Schema

The system requires at least 4 related database tables connected via primary and foreign key constraints:

Table: users

- id (INTEGER PRIMARY KEY AUTOINCREMENT)
- email (TEXT, UNIQUE, NOT NULL)
- hashed_password (TEXT, NOT NULL)
- role (TEXT, NOT NULL) — Enum: 'procurement', 'security', 'vendor'
- vendor_id (INTEGER, NULLABLE, FK -> vendors.id)
- created_at (DATETIME DEFAULT CURRENT_TIMESTAMP)

Table: vendors

- id (INTEGER PRIMARY KEY AUTOINCREMENT)
- company_name (TEXT, NOT NULL)
- contact_email (TEXT, NOT NULL)
- contact_name (TEXT, NOT NULL)
- overall_risk_score (FLOAT, DEFAULT 0.0) — Range: 0.0 - 100.0%
- risk_tier (TEXT, DEFAULT 'Low') — Enum: 'Low', 'Medium', 'High'
- status (TEXT, DEFAULT 'Draft') — Enum: 'Draft', 'Invited', 'Submitted', 'In Security Review', 'Approved', 'Rejected', 'Renewal Due'
- last_submitted_at (DATETIME, NULLABLE)
- last_updated_by (TEXT, NULLABLE) — Metadata tracking for audit logging
- created_at (DATETIME DEFAULT CURRENT_TIMESTAMP)

Table: questionnaire_responses

- id (INTEGER PRIMARY KEY AUTOINCREMENT)
- vendor_id (INTEGER, NOT NULL, FK -> vendors.id)
- section_name (TEXT, NOT NULL) — e.g., 'Access Control', 'Data Encryption', 'Incident Response'
- question_id (TEXT, NOT NULL)
- question_text (TEXT, NOT NULL)
- answer_bool (BOOLEAN, DEFAULT 0) — Yes/No response
- evidence_text (TEXT, NULLABLE)
- is_critical (BOOLEAN, DEFAULT FALSE) — Flag for deal-breaker questions
- points_earned (INTEGER, DEFAULT 0)
- max_points (INTEGER, DEFAULT 10)

Table: document_uploads

- id (INTEGER PRIMARY KEY AUTOINCREMENT)
- vendor_id (INTEGER, NOT NULL, FK -> vendors.id)
- file_name (TEXT, NOT NULL)
- file_path (TEXT, NOT NULL) — Stored in local directory /uploads/
- uploaded_at (DATETIME DEFAULT CURRENT_TIMESTAMP)

3. Database Seed Data

The database seeder pre-loads 5 sample vendors across different lifecycle states:

1. **Acme Corp** (Status: Approved, Score: 92%, Tier: Low)
2. **CloudTech Solutions** (Status: In Security Review, Score: 64%, Tier: High - Triggered by Score < 70%)
3. **DataPipe Systems** (Status: In Security Review, Score: 85%, Tier: High - Triggered by Critical Check Failure: No Encryption at Rest)
4. **LogiFlow Logistics** (Status: Submitted, Score: 78%, Tier: Medium)
5. **Omega Vendors** (Status: Draft, Score: 0%, Tier: Low)

Module 2: Automations, Access Control & Business Logic

1. Mandatory Automation Workflows

The application implements three explicit automation patterns:

1. **Event-Triggered Automation (Vendor Onboarding):** On submission of new vendor details by Procurement, the system creates a vendor profile, generates a unique token link, and triggers an onboarding email notification to the vendor.
2. **Human Approval Step Automation (High-Risk Lock):** When a vendor submits a questionnaire resulting in a high-risk tier (Score < 70% OR critical check failure), status automatically updates to In Security Review. Procurement users are strictly locked from approving the vendor until explicit sign-off from a Security user.
3. **Scheduled Automation (Annual Re-assessment):** A background cron job checks if last_submitted_at > 365 days. If true, status automatically flips to Renewal Due and dispatches a re-assessment reminder notification.

2. Role-Based Access Control (RBAC Matrix)

Access control is enforced at the database and API layer using backend checks (not UI hiding alone):

Role	Create (C)	Read (R)	Update (U)	Delete (D)
Procurement	Vendor Profile, Invites	All Vendor Records, Dashboard Metrics	Low/Medium Risk Vendor Status	None
Security	Audit Comments & Notes	All Vendor Records, High-Risk Queue	High-Risk Status (Approve/Reject), Risk Override	None
Vendor	Document Uploads	Assigned Vendor Profile Only	Questionnaire Responses	None

3. Hybrid Risk Scoring Engine

- **Base Calculation:** Score % = (Sum of Points Earned / Sum of Max Points) * 100
- **High-Risk Triggers:** Automatically flags vendor if Score < 70% OR if any question with is_critical = True has answer_bool = False.
- **Manual Override:** Security users can manually adjust the calculated risk tier (Low, Medium, High) with mandatory override justification notes saved to audit metadata.

Module 3: Data Flow, STRIDE Threat Analysis & GDPR Compliance

1. Data Flow Diagram (DFD Level-1)

The system comprises the following entities, processes, and trust boundaries:

- **External Entities:** External Vendor, Procurement User, Security Officer.
- **Processes:** 1.0 Vendor Onboarding, 2.0 Assessment & Scoring Engine, 3.0 High-Risk Approval Workflow, 4.0 Scheduled Annual Re-assessment.
- **Data Stores:** SQLite Database (users, vendors, responses), Local Storage Directory (/uploads/).
- **Trust Boundaries:** External Vendor Network Boundary vs. Internal Application Server Boundary.

2. STRIDE Threat Analysis Table

Threat Category	Data Flow / Boundary	Identified Risk	Mitigation Strategy
Spoofing	External Vendor -> Portal	Unauthorized access to questionnaire via link guessing	Unique cryptographically secure token/JWT per invite link
Tampering	Vendor -> Assessment Engine	Modification of risk scores in transit	Server-side score calculation and TLS encryption (HTTPS)

Threat Category	Data Flow / Boundary	Identified Risk	Mitigation Strategy
Repudiation	Security Officer -> Approval Flow	Denial of high-risk vendor approval decision	Immutable audit log storing timestamp and user ID in last_updated_by
Information Disclosure	Data Store -> User Interface	Unauthorized access to sensitive vendor SOC 2 documents	Strict RBAC middleware restricting file access to authenticated Security/Procurement roles
Denial of Service	External Vendor -> Local Storage	Storage exhaustion via excessive document uploads	Enforce 10MB file size limits and restrict mime-types to PDF/DOCX
Elevation of Privilege	Procurement -> Approval API	Procurement user approving locked high-risk vendor	Server-side role verification blocking status updates on high-risk vendors for non-Security roles

3. Data Protection & GDPR Write-up

- **Lawful Basis:** Article 6(1)(f) Legitimate Interest — processing is necessary to assess third-party risk and maintain organizational cybersecurity security controls.
- **Data Minimisation:** Personal data collection is restricted strictly to business contact details (name, work email, company name). No special category data is processed.
- **Retention Period:** Vendor contact records and questionnaire data are retained for the active contract duration plus 3 years post-termination for auditing compliance.
- **Data Visibility & Rights:** Personal contact details are visible only to authorized internal Procurement and Security personnel. Vendors maintain the right to update outdated contact details via the portal.

Module 4: Frontend Dashboards, Reporting & Deliverables

1. User Interfaces

- **Procurement Dashboard (/procurement):** Displays summary metrics, full vendor directory table, CSV/PDF export buttons, and "Onboard Vendor" modal form.
- **Security Review Queue (/security):** Displays high-risk vendor queue, failed security controls breakdown, attached compliance documents, and approval/rejection controls.
- **Vendor Portal (/vendor/{id}):** Multi-section questionnaire wizard with file upload fields for SOC 2 / ISO certification attachments.

2. Reporting Exports

- **CSV Export:** Generates directory-wide report containing vendor names, emails, scores,

risk tiers, and lifecycle statuses.

- **PDF Export:** Generates detailed evaluation summaries for individual vendors highlighting failed security checks and approval notes.